Praktische Übung 3 Gefälschte Zahlungsaufforderung

Arbeitszeit 120 Minuten Gruppengröße 3 bis 4 Personen Ergebnis Ausarbeitung und Präsentation

Gruppe	
Namen	

Ausgangssituation

Die fiktive GreenEnergy Solutions GmbH plant Photovoltaikanlagen. Eine Mitarbeiterin der Buchhaltung erhält diese Nachricht:

> *Von: geschäftsfuehrung@greenenergy-solutions.info*
> *Betreff: Vertraulich dringende Zahlung*
>
> *Bitte überweisen Sie noch heute 18.750 Euro auf das im Anhang angeführte Konto. Ich bin momentan nicht telefonisch erreichbar. Behandeln Sie den Vorgang vertraulich.*
>
> *Freundliche Grüße*
> *Markus Berger*
> *Geschäftsführung*

Nach dem Öffnen des Anhangs werden weitere Auffälligkeiten bekannt:

- Die echte Firmenadresse endet auf .at und nicht auf .info.
- Der Geschäftsführer verwendet normalerweise eine digitale Signatur.
- Der Anhang heißt Neue_Bankverbindung.pdf.exe.
- Nach dem Öffnen erscheint kurz ein schwarzes Fenster.
- Der Virenschutz zeigt keine Warnung.
- Eine Datei auf dem Netzlaufwerk wurde verändert.
- Eine Kollegin hat eine ähnliche Nachricht erhalten.
- Die Sicherheitsrichtlinie wurde seit zwei Jahren nicht geschult.
- Die Überweisung wurde noch nicht freigegeben.

Arbeitsauftrag und Zeitplan

1 Warnsignale untersuchen 20 Minuten

Findet mindestens acht technische, sprachliche oder organisatorische Warnsignale. Beschreibt jeweils die mögliche Gefahr.

2 Sicherheitsziele analysieren 20 Minuten

Untersucht Vertraulichkeit, Integrität, Verfügbarkeit, Authentizität und Verbindlichkeit. Bewertet außerdem die Bedeutung der digitalen Signatur und des fehlenden Virenalarms.

3 Ablauf rekonstruieren 15 Minuten

Erstellt eine Zeitleiste. Trennt sichere Beobachtungen von Vermutungen und ergänzt benötigte Informationen.

4 Sofortmaßnahmen planen 25 Minuten

Entwickelt mindestens zehn eindeutige Maßnahmen und reiht sie nach Priorität. Berücksichtigt Computer, Netzwerk, Beweise, Überweisung, Konten, Dateien und weitere Empfänger.

5 Awareness-Maßnahme ausarbeiten 20 Minuten

Erstellt ein Informationsblatt, Poster, fünf Folien oder den Ablauf einer zehnminütigen Kurzschulung. Formuliert einen Merksatz.

6 Präsentation 20 Minuten

Bereitet eine Präsentation von 5 bis 7 Minuten vor und führt sie durch. Alle Gruppenmitglieder übernehmen einen Teil.

Arbeitsblatt 1 Warnsignale

Warnsignal	Kategorie	Begründung	Mögliche Gefahr
Absenderdomain .info statt .at	Technisch, Authentizität	Täuschend ähnliche Domain, typisches Phishing-Merkmal (S. 81)	Antwort und Zahlung landen beim Angreifer
Keine digitale Signatur, obwohl sonst üblich	Technisch, Authentizität, Verbindlichkeit	Signatur belegt Absender und unveränderten Inhalt (S. 141-142)	Gefälschter Absender bleibt unerkannt
Anhang Neue_Bankverbindung.pdf.exe	Technisch, Integrität	Doppelte Dateiendung tarnt ausführbare Datei (S. 89)	Doppelklick startet Malware statt PDF
Kurz schwarzes Fenster nach dem Öffnen	Technisch, Vertraulichkeit, Integrität	Hintergrundprozess, typisch für Trojaner/Skripte (S. 62, 69)	Backdoor, Fernzugriff, Ransomware (S. 69-71)
Virenschutz zeigt keine Warnung	Technisch, Integrität, Vertraulichkeit	Tarnung und neue Malware umgehen Signaturprüfung (S. 62-67)	Falsche Sicherheit, Infektion unbemerkt
Zahlung noch heute, 18.750 Euro, Anhang statt Rechnung	Sprachlich, Authentizität	Dringende Aufforderung ist Phishing-Merkmal (S. 82)	Überweisung ohne Prüfung
Vertraulich behandeln, telefonisch nicht erreichbar	Organisatorisch, Authentizität	Social Engineering: Rückfrage wird verhindert (S. 31-32)	Keine Kontrolle durch Dritte
Ähnliche Mail an Kollegin, Schulung seit 2 Jahren aus	Organisatorisch, alle Sicherheitsziele	Breite Kampagne, mangelnde Awareness (S. 9-10)	Weitere Mitarbeiter fallen darauf herein

Arbeitsblatt 2 Sicherheitsziele

Beobachtung	Sicherheitsziel	Begründung	Mögliche Folge
Absender .info, Mail nicht vom echten Geschäftsführer	Authentizität	Echtheit des Absenders nicht gegeben (S. 7)	Handeln auf Basis falscher Identität
Keine digitale Signatur, Auftrag nicht nachweisbar	Verbindlichkeit	Urheber und Auftrag nicht belegbar (S. 8)	Absender kann alles abstreiten, keine Beweisbasis
Datei auf Netzlaufwerk verändert	Integrität	Daten wurden unautorisiert manipuliert (S. 7)	Falsche oder unbrauchbare Geschäftsdaten
Verdacht auf Trojaner mit Backdoor	Vertraulichkeit	Unbefugter kann Daten einsehen und abgreifen (S. 7, 71)	Abfluss von Finanz- und Firmendaten
Mögliche Ransomware-Vorstufe im Netz	Verfügbarkeit	Daten und Dienste könnten gesperrt werden (S. 8, 69-71)	Betriebsstillstand, Lösegeldforderung
Kein Virenalarm trotz auffälligem Verhalten	Integrität, Vertraulichkeit	Stealth/Tarnung täuscht den Scanner (S. 67-68)	Infektion bleibt unentdeckt, Schaden wächst

Arbeitsblatt 3 Ablauf des Vorfalls

Zeitpunkt	Beobachtung	Mögliche Auswirkung	Fehlende Information
T0: Mail trifft in der Buchhaltung ein	Sicher: .info-Domain, Zeitdruck, Geheimhaltung	Initial Access per E-Mail/Phishing (S. 70)	Eingangszeit, Mail-Header, Spamfilter-Ergebnis
T1: Anhang .pdf.exe wird geöffnet	Sicher: geöffnet. Vermutung: Trojaner gestartet	Rechner potenziell infiziert, Backdoor möglich	Welche Datei lief, Prozess- und Logdaten
T1+: Schwarzes Fenster, kein Virenalarm	Sicher: kein Alarm. Vermutung: Tarnung oder alte Signaturen	Infektion bleibt unbemerkt (S. 62-67, 100)	Signaturstand, Echtzeitschutz aktiv?
T2: Datei auf Netzlaufwerk verändert	Sicher: Änderung. Vermutung: Lateral Movement (S. 70)	Ausbreitung im Netz, Datenmanipulation	Welche Datei, wann, von welchem Konto
Kollegin erhält ähnliche Nachricht	Sicher: ähnliche Mail. Vermutung: Kampagne	Weitere Opfer möglich	Hat sie geklickt? Weitere Empfänger?
Jetzt: Überweisung nicht freigegeben	Sicher: noch kein Geld abgeflossen	Finanzieller Schaden bisher verhindert	Wer stoppt sie? Bank schon informiert?

Arbeitsblatt 4 Sofortmaßnahmen

Priorität	Maßnahme	Begründung	Sicherheitsziel
1	Rechner vom Netzwerk trennen, nicht ausschalten	Stoppt Ausbreitung (S. 70), Spuren bleiben erhalten	Verfügbarkeit, Integrität
2	IT-Sicherheitsbeauftragten und IT sofort melden	Zuständig für Umsetzung der Policy (S. 107)	Alle Ziele
3	Überweisung nicht freigeben, Zahlung sperren	Verhindert direkten finanziellen Schaden	Authentizität
4	Geschäftsführer über bekannte Nummer zurückrufen	Zweiter Kanal klärt Echtheit des Auftrags (S. 7)	Authentizität
5	Mail und Anhang unverändert als Beweis sichern	Nachweis für Forensik und Anzeige (S. 8)	Verbindlichkeit
6	Bank informieren, Zahlungen prüfen lassen	Rückholung nur zeitnah möglich	Verfügbarkeit
7	Netzlaufwerk prüfen, Offsite-Backups sichern	Schutz vor Datenverlust und Ransomware (S. 71)	Integrität, Verfügbarkeit
8	Passwörter ändern (Mail, Laufwerk, VPN)	Zugangsdaten könnten abgegriffen sein (S. 71, 80)	Vertraulichkeit

Anforderungen an die Awareness Maßnahme

- Absenderadresse kontrollieren
- Gefährliche Dateiendungen erkennen
- Unerwartete Anhänge nicht öffnen
- Ungewöhnliche Zahlungsaufforderungen über zweiten Kanal prüfen
- Zeitdruck und Geheimhaltung als Warnsignale beachten
- Interne Meldestelle nennen
- Richtiges Verhalten nach einem Fehlklick erklären

Präsentationsauftrag

- Vorfall zusammenfassen
- Wichtigste Warnsignale erläutern
- Betroffene Sicherheitsziele erklären
- Fünf Sofortmaßnahmen vorstellen
- Awareness-Maßnahme präsentieren
- Drei Empfehlungen an die Geschäftsführung geben

Ergänzungsblatt zur Ausarbeitung

Grundlage: Skript Netzwerke Sicherheit (NWSI_2024, Gauer, HERDT-Verlag). Seitenangaben beziehen sich auf das Skript.

Weitere Warnsignale (Ergänzung zu Arbeitsblatt 1)

- **Unpersönliche Anrede:** kein Name der Empfängerin, nur ein allgemeiner Befehl (S. 82).
- **Bankverbindung als ausführbarer Anhang** statt über den üblichen Freigabeprozess.
- **Änderung am Netzlaufwerk:** deutet auf Phase 2 des Angriffs hin (Consolidation, Lateral Movement, S. 70).
- **Betreff „Vertraulich dringende Zahlung“:** Dringlichkeit plus Sicherheits-/Geheimhaltungsargument (S. 82).

Bewertung: digitale Signatur und fehlender Virenalarm (Arbeitsauftrag 2)

Digitale Signatur (S. 141-142): Aus der Nachricht wird ein Hashwert gebildet und mit dem privaten Schlüssel des Absenders verschlüsselt. Der Empfänger entschlüsselt mit dem öffentlichen Schlüssel und vergleicht beide Fingerabdrücke. Stimmen sie überein, ist der Absender echt (Authentizität), der Inhalt unverändert (Integrität) und der Absender kann es nicht abstreiten (Verbindlichkeit). In der EU ist sie seit 2016 als rechtskräftige Unterschrift zugelassen (eIDAS). Fehlt sie bei einem Absender, der sie normalerweise nutzt, ist das ein starkes Indiz für eine Fälschung.

Fehlender Virenalarm (S. 62-68, 100): Virenscanner arbeiten mit Signaturen. Verschlüsselnde, polymorphe und Stealth-Viren umgehen diese Prüfung, ein Stealth-Virus täuscht dem Scanner sogar saubere Daten vor. Zudem schützt der Scanner nur bei aktuellen Signaturen und aktivem Echtzeitschutz. Kein Alarm bedeutet daher nicht „sauber“. Das Verhalten (schwarzes Fenster, veränderte Datei) wiegt schwerer als der Scanner-Status.

Arbeitsblatt 4: Sofortmaßnahmen 9 bis 12 (Fortsetzung)

Prio.	Maßnahme	Begründung	Sicherheitsziel
9	Kollegin und alle Mitarbeiter warnen, weitere Empfänger prüfen	Breite Kampagne, verhindert weitere Klicks (S. 10)	Alle Ziele
10	Rechner nur mit Antivirensoftware von sauberem, bootfähigem Medium prüfen und bereinigen lassen, nicht selbst löschen	Stealth-Viren täuschen Scanner im laufenden System (S. 68, 99)	Integrität
11	Vorfall bei Polizei/Cybercrime-Meldestelle anzeigen	Rechtliche Verfolgung, Bankunterstützung	Verbindlichkeit
12	Spamfilter/Blacklist anpassen, Dateiendungen im Explorer anzeigen lassen	Verhindert Wiederholung (S. 82, 88-89)	Authentizität, Integrität

Awareness-Maßnahme: Kurzschulung und Aushang „Stopp vor dem Klick“

Format laut Skript: Kurzveranstaltung, Aushang am „Schwarzen Brett“ und Rundmail, regelmäßig wiederholt (S. 10, 243). Die gesamte Belegschaft wird geschult, nicht nur die IT, denn Mitarbeiter öffnen unverlangte Anhänge eher aus Neugier als Administratoren (S. 10).

- **Absender prüfen:** Domain genau lesen (.at statt .info), täuschend ähnliche Domains erkennen (S. 81).
- **Gefährliche Dateiendungen erkennen:** Endungen im Explorer einblenden, doppelte Endungen wie .pdf.exe sind ausführbar (S. 88-89).
- **Unerwartete Anhänge nicht öffnen**, auch wenn sie dringend wirken.
- **Ungewöhnliche Zahlungsaufforderung über zweiten Kanal prüfen:** Rückruf unter bekannter Nummer, Vier-Augen-Prinzip.
- **Zeitdruck und Geheimhaltung beachten:** typische Merkmale von Phishing und Social Engineering (S. 31, 82).
- **Meldestelle:** IT-Sicherheitsbeauftragter/IT-Hotline, am Arbeitsplatz und im Intranet sichtbar (S. 107).
- **Nach einem Fehlklick:** Netzwerkkabel/WLAN trennen, Rechner nicht selbst „aufräumen“, sofort melden (S. 99). Schnelles Melden zählt, keine Schuldzuweisung.

Merksatz: „Dringend, geheim, ungewöhnlich? Erst prüfen, dann handeln!“

Ablauf der Kurzschulung (10 Minuten)

Min.	Inhalt	Methode
0-2	Fall GreenEnergy vorstellen, Mail zeigen	Beispiel-Mail als Folie
2-5	Warnsignale gemeinsam finden (Domain, Endung, Druck)	Teilnehmer markieren in der Mail
5-7	Richtig reagieren: Zweitkanal, Meldestelle, Fehlklick	Kurzvortrag mit Checkliste
7-9	Quiz: Welche Dateiendung ist gefährlich?	Drei Beispiele, Handzeichen
9-10	Merksatz, Meldeadresse, Aushang verteilen	Zusammenfassung

Präsentation (5 bis 7 Minuten, jedes Gruppenmitglied übernimmt einen Teil)

• **Vorfall zusammenfassen (1 Min.):** Gefälschte Mail des Geschäftsführers, Eilüberweisung 18.750 Euro, Anhang .pdf.exe, Verdacht auf Trojaner.
• **Wichtigste Warnsignale (1,5 Min.):** falsche Domain, fehlende Signatur, doppelte Endung, Zeitdruck und Geheimhaltung.
• **Betroffene Sicherheitsziele (1 Min.):** Authentizität, Verbindlichkeit, Integrität, Vertraulichkeit, Verfügbarkeit.
• **Fünf Sofortmaßnahmen (1,5 Min.):** Rechner trennen, Meldung, Überweisung stoppen, Rückruf per zweitem Kanal, Beweise sichern.
• **Awareness-Maßnahme (1 Min.):** Aushang, Kurzschulung und Merksatz vorstellen.

Drei Empfehlungen an die Geschäftsführung

1. **Security Policy mit Notfallplan** schriftlich festlegen, allen Mitarbeitern bekannt machen und Verstöße regeln (S. 106-107). Der IT-Sicherheitsbeauftragte ist der Geschäftsführung direkt unterstellt und koordiniert die Schulungen.
2. **Regelmäßige Awareness-Schulungen** für die gesamte Belegschaft, mindestens jährlich, ergänzt durch Aushänge und Rundmails (S. 10, 243).
3. **Technische und organisatorische Absicherung:** digitale Signatur verbindlich nutzen (S. 141-142), Vier-Augen-Prinzip mit Rückruf bei Überweisungen, Spamfilter und Blockieren ausführbarer Anhänge, aktuelle Signaturen, Echtzeitschutz und Offsite-Backups (S. 71, 82, 100).